

The Grand Marina Hotel — HYDROLOGIC Water Monitoring System

Prepared for: Marcus Webb, General Manager & Sandra Chen, Auditor from Pacific Mutual

Prepared by: Christine Khayat, Junior Security Engineer

Date: September 27, 2026

1. EXECUTIVE SUMMARY

Testing identified a weakness in the Grand Marina's water monitoring system: an attacker could record a legitimate message and replay it later, causing the system to accept old information as if it were new. We tested three protections against immediate, delayed, and tampered replays, and found that each individual protection had limitations, while using all three together rejected 100% of the tested attacks. We recommend deploying all three protections across the hotel's water monitoring system.

2. THE PROBLEM

A replay attack is similar to someone recording a legitimate garage door opener signal and playing the recording later. The signal is genuine, but it is being reused at the wrong time.

What could go wrong:

- **Phantom shutoff:** An attacker could record a legitimate maintenance command and replay it later, potentially causing a water system component to shut off unexpectedly.
- **Stale reading:** An old sensor reading could be replayed and accepted as current, potentially hiding a real pressure problem, blockage, or leak.
- **Repeated billing event:** Replayed water usage information could cause the system to record the same event again, potentially creating false water-usage or overage charges.

3. DEFENSES TESTED

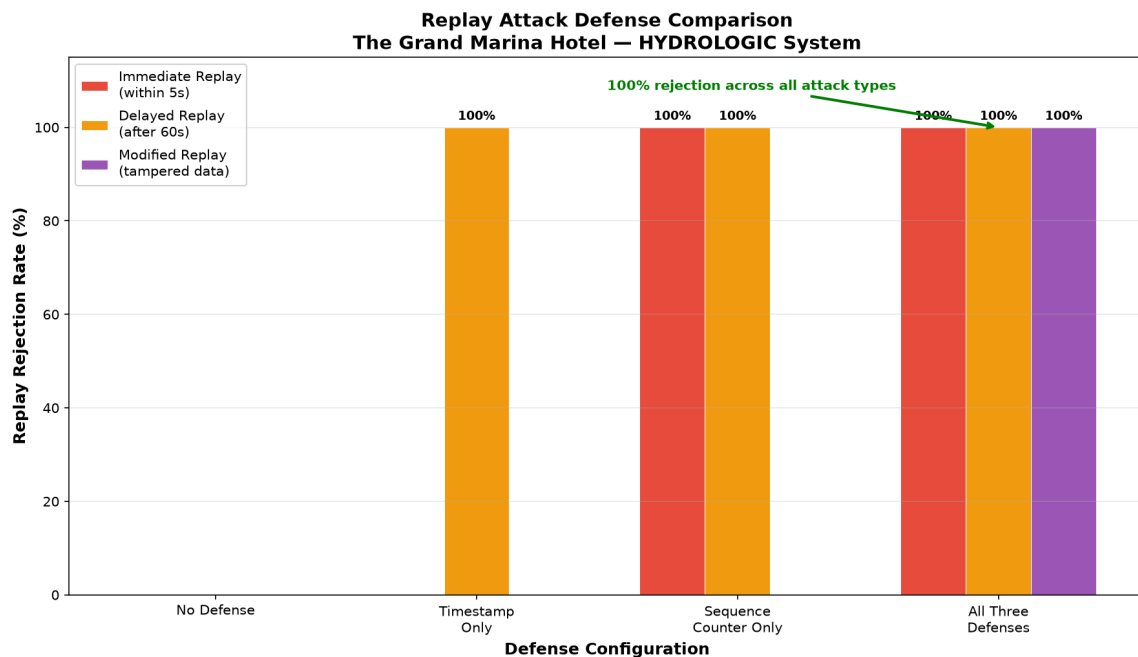
1. **Message freshness check:** Each message is checked to make sure it is recent and has not passed its allowed time window, similar to a parking ticket that is only valid for a specific period.
2. **Message numbering:** Each message receives a sequence number that must move forward, similar to a concert ticket with a unique number that cannot be reused.

3. Message signing: Each message contains a tamper-evident digital signature that allows the system to detect if its contents have been changed, similar to a sealed letter.

4. TESTING RESULTS

We tested four protection configurations against three types of replay attacks: immediate replay, delayed replay, and tampered replay. The percentages below show the percentage of five attack attempts that were rejected by each protection setup.

Protection Setup	Immediate Replay	Delayed Replay	Tampered Replay
No protection	0%	0%	0%
Message freshness check only	0%	100%	0%
Message numbering only	100%	100%	0%
All three combined	100%	100%	100%



Key finding: Individual protections had gaps. The freshness check stopped delayed messages but could not stop immediate or tampered replays, while message numbering stopped immediate and delayed replays but did not detect tampering. The only configuration that rejected all three tested attack types was the combination of all three protections, which achieved a 100% rejection rate in every test category.

5. RECOMMENDATION

We recommend deploying all three protections across the Grand Marina's HYDROLOGIC water monitoring system.

Why all three:

- Coverage: Each protection addresses a different weakness. Combining them prevents an attacker from bypassing the system by exploiting the limitation of any single protection.
- Performance: The three checks together take less than one millisecond per message, which is negligible compared with the five-second interval between normal sensor readings. The added processing does not meaningfully affect normal operations.
- Readiness: The defended publisher and subscriber have already been built and tested successfully. Deployment would involve replacing the current versions with the defended versions and applying the protections to the hotel's monitoring devices.

6. NEXT STEPS

- Deploy the defended software to all three HYDROLOGIC devices and verify that legitimate sensor messages continue to be accepted.
- Enable monitoring and logging for rejected messages so the security team can investigate repeated or suspicious activity.
- Add the replay-detection results to the hotel's security documentation and periodically retest the protections to confirm they continue working as expected.

7. INDUSTRY REFERENCES

- AWS IoT Core: AWS IoT Core supports MQTT and MQTT 5 features including message expiry, providing mechanisms for managing the lifetime of messages.
- IEC 62443: IEC 62443 provides cybersecurity guidance for industrial automation and control systems, including protections for the integrity and secure handling of system communications.
- MQTT 5: MQTT 5 includes a Message Expiry Interval that allows messages to have a defined lifetime so that expired messages are not delivered.